

Athens, 27-11-2024

Ref. No.: 3364

DECISION 43/2024

The Hellenic Data Protection Authority convened at the invitation of its President via teleconference on 26/04/2024, in order to examine the case referred to below in the background of this decision. Present were the President of the Authority, Konstantinos Menoudakos, and the regular members Konstantinos Lamprinoudakis, Spyridon Vlachopoulos, Christos Kalloniatis, Charalampos Anthopoulos, Grigorios Tsolias, the alternate member Nikolaos Faldamis replacing the regular member Aikaterini Iliadou, who, although duly summoned in writing, did not attend due to an impediment, and the alternate member Nikolaos Libos as rapporteur without voting rights pursuant to Article 8, paragraph 2 of the Authority's Operating Regulation. Present without voting rights were Eleni Maragkou, special scientist - lawyer, Georgia Panagopoulou, and Aikaterini Chatzidiakou, special scientists - computer scientists, as assistants to the rapporteur, and Irini Papageorgopoulou, employee of the administrative affairs department, as secretary. The Authority took into account the following:

As part of a broader initiative by the European Data Protection Board (hereinafter, EDPB), the Hellenic Data Protection Authority (hereinafter, the Authority), along with the majority of EDPB members, jointly undertakes the examination of a matter in a coordinated manner. For 2023, the EDPB decided to prioritize the issue "The definition and position of the Data Protection Officer." For this purpose, the EDPB developed a unified questionnaire regarding the definition and position of the Data Protection Officer (hereinafter, DPO), which the Authority adopted and sent to selected public entities.

2

As a participating member in this action, the Authority has additionally chosen to exercise its investigative powers, as provided by Article 58 of the GDPR, in order to verify the definition and position of the DPO in the public sector in light of the existing legal obligation (Articles 37-39 of the GDPR and Articles 6-8 of Law 4624/2019). The Authority's coordinated action team, consisting of special scientists E. Maragkou, G. Panagopoulou, and A. Chatzidiakou, sent the questionnaire to 31 public entities on 03-05-2023. Among them was the Ministry of Climate Crisis and Civil Protection (hereinafter, data controller), to which the coordinated action team sent the questionnaire with reference number G/EXE/1124/03-05-2023, with a deadline for submission via the EUsurvey link by 19-05-2023. The data controller did not respond to the aforementioned document. The Authority resent the questionnaire to the data controller with reference number G/EXE/1350/29-05-2023, in which the data controller was invited to respond by 31-05-2023. The data controller did not respond to the above reminder. A search on the data controller's website revealed that there were no posted details of the DPO. Furthermore, based on the DPO registry maintained by the Authority, it was confirmed that the data controller had not announced DPO contact details, as required under Article 37, paragraphs 1 and 7.

Subsequently, after the Authority reviewed the case file, it sent the reference number G/EXE/3018/28-11-2023 summons to the data controller in order to discuss the case before the Plenary of the Authority on Tuesday, December 19, 2023. During the session, the discussion of the case was postponed at the request of the data controller for the session of 09-01-2024. Following the receipt of the above summons to the Plenary of the Authority, the data controller sent the Authority the reference number G/EIS/9143/22-12-2023 memorandum, in which it transmitted the questionnaire confirming through its responses that it had not appointed a DPO despite the fact that the appointment is mandatory. In the session of 09-01-2024, which took place via teleconference, representatives of the data controller, A, ... of the Ministry of Climate Crisis and Civil Protection, and Panagioula Makri, Legal Advisor in the Minister's Office with reference number ..., were present. Subsequently, the data controller

3

The data controller submitted, within the deadline set by the Authority during the aforementioned

meeting following his relevant request, the document with reference number G/EIΣ/654/26-01-2024, in which he essentially reiterated the claims he had previously made before the Authority. In his memorandum, he emphasizes that a) a draft Presidential Decree has been sent, which includes organizational changes covering the field of personal data protection and is pending processing by the General Accounting Office of the State, b) the delay in compliance is due to changes in the structure and composition of the Ministry, specifically the addition of the General Secretariat for Assistance, c) the Ministry was established in September 2021, and services were transferred from the Ministry of Citizen Protection, while a transitional period was provided regarding the final subordination of employees and the transfer of funds until 31.12.2022, d) a contract has been concluded with an external consultant for the support of compliance with the GDPR, and a supportive working group has been formed with representation from all critical departments of the Ministry for the maintenance of data protection procedures, and additionally, a DPO will be appointed. Furthermore, with the aforementioned memorandum, the data controller sent the project contract (01/2024) with the contractor company named "ODYSSEY CONSULTANTS LTD – FOREIGN BRANCH" for the provision of consulting services for compliance with the GDPR. Finally, the data controller, through the memorandum, sent the electronic communication between the head of the Administration and Support Directorate, who ultimately completed the aforementioned questionnaire (which was submitted to the Authority by the data controller with the above reference number G/EIΣ/9143/22-12-2023), and other representatives of the Ministry, which took place on 06-06-2023, that is, after the deadline of 31-05-2023 that had been set for the submission of the questionnaire, and while the link to the platform had been disabled by the Authority, as had been provided for in the context of the audit process. The Authority, after examining the contents of the file, determined that new elements had emerged that required further examination and issued decision number 4/2024 and sent a new summons with reference number G/EΞE/555/14-02-2024 to the data controller in order to discuss the case again in its entirety before the Plenary of the Authority on 23-02-2024. During this meeting, the case was postponed at the request of the data controller for the meeting of 12-03-2024, for which the Authority sent again the summons with reference number G/EΞE/647/23-02-2024 in order to discuss before the Plenary of the Authority, in addition to the compliance of the data controller with Articles 31 and 37 of the GDPR, the compliance and obligations arising from the GDPR in relation to the rights of data subjects under the provisions of Chapter 3, as well as the obligations of the data controller under the provisions of Chapter 4.

In this last meeting, which was held via videoconference, A, ... from the Ministry of Climate Crisis and Civil Protection, represented the data controller. Subsequently, the data controller submitted, within the deadline set by the Authority during the aforementioned meeting following his relevant request, the document with reference number G/EIΣ/2962/29-03-2024, in which he essentially reiterated the claims he had previously made before the Authority regarding the establishment of the Ministry, the lack of resources, and the conclusion of a contract for compliance with the GDPR. In his memorandum, he emphasizes that as of 12-02-2024, the decision with reference number ... appointing a DPO for the General Secretariat of Civil Protection of the Ministry of Climate Crisis and Civil Protection is in effect. Additionally, it is mentioned in the aforementioned memorandum that there is already a DPO with authority over the data protection issues of the Fire Brigade. However, a search on the website of the data controller revealed that there were no posted details of the DPO either for the entire General Secretariat or for the Fire Brigade. Furthermore, based on the DPO registry maintained by the Authority, it was confirmed that the data controller has not announced contact details for the DPO as required under Article 37 paragraphs 1 and 7. Finally, regarding compliance issues, the data controller stated that the delay in compliance with the GDPR is due to changes in the structure and composition of the Ministry, as the Ministry is newly established and has had a total transfer of responsibilities, positions, and personnel. Additionally, he mentioned that the addition of the General Secretariat for Natural Disaster Recovery and State Assistance to the Ministry has recently taken place, and the transfer of responsibilities and personnel will be ongoing until 31-12-2024, while the administrative subordination of personnel and financial support for the aforementioned added General Secretariat will be in progress.

The Secretariat continues to be under the jurisdiction of the Ministry of Finance from which it originated.

The Authority, after examining the elements of the file and those arising from the hearing before it and the submissions of the data controller, along with their supplementary documents, having heard the rapporteur and the clarifications from the assistant rapporteurs, who attended without voting rights, after thorough discussion,

CONSIDERED IN ACCORDANCE WITH THE LAW

1. Since, from the provisions of Articles 51 and 55 of the GDPR and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the jurisdiction to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data and to exercise the powers assigned to it under the aforementioned regulation.

2. Since according to the definitions of Article 58 of the GDPR: "1. Each supervisory authority shall have all of the following investigative powers: a) to order the data controller and the processor and, where applicable, the representative of the data controller or the processor to provide any information it requires for the performance of its tasks, b) to conduct investigations in the form of checks on data protection,... d) to notify the data controller or the processor of an alleged infringement of this regulation, e) to obtain from the data controller and the processor access to all personal data and all information necessary for the performance of its tasks..."

3. Since according to the definitions of Articles 13 and 15 of Law 4624/2019 respectively: "1. In addition to its duties under Article 57 of the GDPR, the Authority: ...h) conducts investigations or checks ex officio or upon complaint for the application of this law and other regulations concerning the protection of individuals against the processing of personal data, among others based on information from another public authority..." and "1. In addition to the powers provided for in Article 58 of the GDPR, the Authority conducts investigations and checks ex officio or upon complaint regarding compliance with this law, within which the technological infrastructure and other, automated or non-automated means supporting the processing of personal data are checked. During the conduct of investigations and checks, the Authority has the power to obtain from the data controller and the processor access to all personal data being processed and all information necessary for the purposes of the relevant check and the performance of its tasks, without any kind of confidentiality being able to be invoked against it..."

4. Since according to the definitions of Article 5 of the GDPR "1. Personal data shall be: a) processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness and transparency'),..., c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimization'),..., f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organizational measures ('integrity and confidentiality'). 2. The data controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ('accountability').

5. Since according to the definitions of Article 31 of the GDPR: "The data controller and the processor and, where applicable, their representatives shall cooperate, on request, with the supervisory authority in the performance of its tasks."

6. Since according to the definitions of Article 37 of the GDPR: "1. The data controller and the processor shall designate a data protection officer in any case where: a) the processing is carried out by a public authority or body, except for courts acting in their judicial capacity,... 3. If the data controller or the processor is a public authority or body, a single data protection officer may be designated for several such authorities or bodies, taking into account their organizational structure and size,... 5. The data protection officer is appointed.

7

based on professional qualifications and particularly based on the expertise they possess in the field of law and data protection practices, as well as based on the ability to fulfill the duties referred to in Article 39. 6. The data protection officer may be a member of the staff of the data controller or the processor

or may perform their duties under a service contract. 7. The data controller or the processor shall publish the contact details of the data protection officer and communicate them to the supervisory authority.

7. Whereas according to the definitions of Article 38 of the GDPR: “1. The data controller and the processor ensure that the data protection officer is involved, properly and in a timely manner, in all issues related to the protection of personal data. 2. The data controller and the processor support the data protection officer in the performance of the tasks referred to in Article 39 by providing the necessary resources for the performance of those tasks and access to personal data and processing operations, as well as resources necessary to maintain their expertise. 3. The data controller and the processor ensure that the data protection officer does not receive instructions regarding the performance of those tasks. They are not dismissed or subjected to penalties by the data controller or the processor for having performed their duties. The data protection officer reports directly to the highest management level of the data controller or the processor. 4. Data subjects can contact the data protection officer for any issues related to the processing of their personal data and the exercise of their rights under this regulation. 5. The data protection officer is bound by the obligation of confidentiality regarding the performance of their duties, in accordance with Union or Member State law. 6. The data protection officer may also perform other tasks and obligations. The data controller or the processor ensure that such tasks and obligations do not lead to a conflict of interest.”

8

8. Whereas according to the definitions of Article 39 of the GDPR: “1. The data protection officer has at least the following tasks: a) to inform and advise the data controller or the processor and the employees who process their obligations arising from this regulation and from other provisions of Union or Member State law regarding data protection, b) to monitor compliance with this regulation, with other provisions of Union or Member State law regarding data protection and with the policies of the data controller or the processor in relation to the protection of personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and related audits, c) to provide advice, when requested, regarding the data protection impact assessment and to monitor its implementation in accordance with Article 35, d) to cooperate with the supervisory authority, e) to act as a contact point for the supervisory authority on issues related to processing, including prior consultation referred to in Article 36, and to consult, as appropriate, on any other matter. 2. In the performance of their tasks, the data protection officer shall take due account of the risks associated with processing operations, considering the nature, scope, context, and purposes of the processing.”

9. Whereas according to the definitions of Article 12 of the GDPR: “1. The data controller takes appropriate measures to provide the data subject with all information referred to in Articles 13 and 14 and any communication in the context of Articles 15 to 22 and Article 34 regarding processing in a concise, transparent, intelligible, and easily accessible form, using clear and plain language, particularly when addressing information specifically to children. The information is provided in writing or by other means, including, where appropriate, electronically. When requested by the data subject, the information may be provided orally, provided that the identity of the data subject is proven by other means. 2. The data controller facilitates the exercise of the rights of data subjects.

9

of the data provided for in Articles 15 to 22. In cases provided for in Article 11, paragraph 2, the data controller shall not refuse to act upon the request of the data subject to exercise their rights under Articles 15 to 22, unless the data controller demonstrates that it is unable to verify the identity of the data subject. 3. The data controller shall provide the data subject with information on the action taken in response to the request under Articles 15 to 22 without undue delay and in any event within one month of receiving the request. This deadline may be extended by a further two months, if necessary, taking into account the complexity of the request and the number of requests. The data controller shall inform the data subject of such an extension within one month of receiving the request, as well as the reasons for the delay. If the data subject submits the request by electronic means, the information shall be provided, where possible, by electronic means, unless the data subject requests otherwise. 4. If the

data controller does not act on the request of the data subject, the data controller shall inform the data subject, without undue delay and at the latest within one month of receiving the request, of the reasons for not acting and of the possibility of lodging a complaint with a supervisory authority and seeking a judicial remedy. 5. The information provided in accordance with Articles 13 and 14 and any communication as well as all actions taken in accordance with Articles 15 to 22 and Article 34 shall be provided free of charge. If the requests from the data subject are manifestly unfounded or excessive, in particular due to their repetitive nature, the data controller may either: a) charge a reasonable fee, taking into account the administrative costs of providing the information or communication or taking the requested action, or b) refuse to act on the request. The data controller bears the burden of demonstrating the manifestly unfounded or excessive nature of the request. 6. Subject to Article 11, when the data controller has reasonable doubts concerning the identity of the natural person making the request referred to in Articles 15 to 21, the data controller may request the provision of additional information necessary to confirm the identity of the data subject. 7. The information to be provided to data subjects in accordance with Articles 13 and 14 may be provided in combination with standardized icons in order to give a clear, understandable, and easily readable overview of the intended processing. If the icons are made available electronically, they are machine-readable. 8. The Commission is empowered to adopt delegated acts in accordance with Article 92 to specify the information to be presented with the icons and the procedures for providing standardized icons.

10. Whereas according to the definitions in Article 25 of the GDPR: "...2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data which are necessary for each specific purpose of the processing are processed. This obligation applies to the scope of personal data collected, the extent of their processing, the retention period, and their accessibility. In particular, such measures ensure that, by default, personal data are not made accessible without the intervention of the data subject to an indefinite number of natural persons..."

11. Whereas according to the definitions in Article 30 of the GDPR: "1. Each data controller and, where applicable, its representative, shall maintain a record of processing activities under its responsibility. The record shall include all of the following information: a) the name and contact details of the data controller and, where applicable, of the joint data controller, the representative of the data controller, and the data protection officer, b) the purposes of the processing, c) a description of the categories of data subjects and of the categories of personal data, d) the categories of recipients to whom the personal data have been or will be disclosed, including recipients in third countries or international organizations, e) where applicable, the transfers of personal data to a third country or an international organization, including the identification of that third country or international organization and, in the case of transfers referred to in Article 49.

11. Paragraph 1 second subparagraph, of the documentation of appropriate guarantees, (st) where possible, the specified deadlines for the deletion of various categories of data, (z) where possible, a general description of the technical and organizational security measures referred to in Article 32 paragraph 1., ..., 3. The records referred to in paragraphs 1 and 2 exist in writing, among others in electronic form. 4. The data controller or the processor and, where applicable, the representative of the data controller or the processor shall make the record available to the supervisory authority upon request...

12. Whereas according to the definitions of Article 32 of the GDPR: "1. Taking into account the latest developments, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, including, among others, as appropriate: (a) the pseudonymization and encryption of personal data, (b) the ability to ensure the confidentiality, integrity, availability, and resilience of processing systems and services on a continuous basis, (c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, (d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures for ensuring the security of processing. 2. In assessing the appropriate level of security, account shall be taken in particular of the risks that arise

from the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed..."

13. Whereas in this case, from the elements of the case file, it initially appears that the data controller did not timely submit the above questionnaire in violation of Article 31 of the GDPR.

14. Whereas additionally, it was found that the data controller had not appointed a Data Protection Officer (DPO) since its establishment. Following the summons to the Authority, the data controller appointed a DPO for the entire General Secretariat while also mentioning the existence of a designated DPO for the IT system, without, however, having notified their details to the Authority, nor having posted the necessary contact information on the website, while no DPO had been appointed for the Ministry as a whole as the data controller. The data controller, during the summons and in its submissions, cited issues of resources and coverage of operational positions.

15. Whereas the data controller had not complied with the GDPR since its establishment, and specifically with the provisions of Chapters 3 and 4 of the GDPR, as it was obliged to do based on the principle of accountability, while as appears from the history of the present case, the data controller merely invoked the fact that it is a newly established Ministry and therefore had not had the opportunity to comply with the requirements of the GDPR, and entered into a contract with an external partner for the above compliance following the summons from the Authority. Specifically, the data controller had not taken appropriate measures to provide data subjects with transparent information regarding their rights, as well as facilitation for the exercise of those rights, as provided for in Article 12 of the GDPR. Additionally, the data controller had not taken and implemented appropriate organizational measures for the protection of personal data and specifically for ensuring the processing of personal data by design and by default for personal data that is necessary for the specific purpose of processing, as provided for in Article 25 of the GDPR. Moreover, the data controller had not maintained the record of processing activities as required by Article 30 of the GDPR. Furthermore, the data controller had not taken and implemented appropriate technical and organizational measures to ensure an appropriate level of security against risks, in accordance with the requirements of Article 32 of the GDPR.

16. Whereas, as can be seen from the above, violations of Articles 12, 32, 25, and 30 were identified, and a violation of the principles of legality as they are...

1 See recent CJEU decision in case C-184/20 - Vyriausioji tarnybinės etikos komisij (para. 89):

"However, it should be emphasized that the lack of available resources for public authorities cannot in any case constitute a legitimate reason capable of justifying the infringement of the fundamental rights enshrined in the Charter."

13

are described in Article 5 paragraph 1 subparagraph a', 5 paragraph 1 subparagraph c' and 5 paragraph 1 subparagraph f', given that the violation of the obligations of the data controller for transparent information, for data protection by design and by default, and for security as well as for maintaining records of processing activities arises from the aforementioned principles of Article 5 and constitutes a violation of these.

17. Because, based on the above, the Authority finds the following:

- a. Violation of Article 31 regarding the cooperation of the data controller with the Authority.
- b. Violation of Article 37 regarding the non-designation of a DPO.
- c. Violation of Article 12 regarding transparent information, communication, and arrangements for the exercise of the rights of the data subject and of Article 32 paragraphs 1 and 2 regarding the security of processing in conjunction with Article 5 paragraph 1 subparagraph a', 5 paragraph 1 subparagraph c' and 5 paragraph 1 subparagraph f' regarding transparency, minimization, integrity, and confidentiality of data.
- d. Violation of Article 25 regarding data protection by design and by default.
- e. Violation of Article 30 regarding the maintenance of a record of processing activities.

18. Because based on the above, the Authority deems that there is a case for exercising its corrective powers under Article 58 paragraph 2 GDPR and imposing an administrative sanction in relation to the identified violations.

19. Because the Authority further considers that, based on the violations identified, an effective, proportionate, and deterrent administrative monetary fine should be imposed, in application of the provision of Article 58 paragraph 2 subparagraph h' GDPR, in accordance with Articles 83 GDPR and 39 of Law 4624/2019, on the data controller.

20. Because further the Authority took into account the criteria for assessing the fine as defined in Article 83, paragraph 2 of the GDPR, paragraphs 4 and 5 of the same article applicable to the present case, Article 39 paragraphs 1 and 2 of Law 4624 concerning the imposition of administrative sanctions on public sector entities, and the Guidelines 04/2022 of the European Data Protection Board for the calculation of administrative fines under the GDPR which were approved on 24/5/2023, as well as the factual circumstances/data of the case under examination and in particular the following:

- i) The fact that the data controller, as a public entity, had not designated a DPO since its establishment despite the obligation to do so, resulting in the violation having a long duration, while even with the recent designation of a DPO at the General Secretariat, the lack of designation of a DPO for the Ministry as the data controller remains.
- ii) The fact that the data controller has not complied with the GDPR since its establishment, despite the obligation to do so, resulting in the violation having a long duration.
- iii) The fact that the data controller did not notify the above violations to the Authority, but on the contrary, the Authority was informed through the audit it conducted as part of the coordinated action.
- iv) The fact that the data controller operates at a national level increases the severity of the extent of the processing.
- v) The fact that it cannot be confirmed whether material damage occurred to the data subjects, as well as the number of potentially affected data subjects.
- vi) The fact that the data controller showed reluctance to cooperate with the Authority, failing to provide the requested information in a timely manner.
- vii) The fact that, although late, the data controller eventually submitted the above questionnaire.
- viii) The fact that no previous similar violation of non-cooperation with the Authority has been established against the data controller.

The Authority deems that, based on the violations identified, the sanction referred to in the operative part of the decision is the effective, proportionate, and deterrent measure to restore compliance.

2 https://www.edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativelines_el_0.pdf

15

FOR THESE REASONS

The Authority, taking into account the above:

- a) Imposes based on Article 58 paragraph 2 subparagraph h' of the GDPR, an administrative fine on the Ministry of Climate Crisis and Civil Protection totaling 5,000 euros, for the violation of Article 31 of Regulation (EU) 2016/679.
- b) Imposes based on Article 58 paragraph 2 subparagraph h' of the GDPR, an administrative fine on the Ministry of Climate Crisis and Civil Protection totaling 25,000 euros, for the violation of Article 37 of Regulation (EU) 2016/679.
- c) Imposes based on Article 58 paragraph 2 subparagraph h' of the GDPR, an administrative fine on the Ministry of Climate Crisis and Civil Protection totaling 20,000 euros, for the violations of Articles 12 and 32 paragraphs 1 and 2, in conjunction with Article 5 paragraph 1 subparagraph a', c', and f', as well as Articles 25 and 30 of Regulation (EU) 2016/679.

The President

The Secretary

Konstantinos Menoudakos

Irini Papageorgopoulou